

**MEDICARE CONNECT (PTY) LTD
CLOUD ENVIRONMENT SCOPE DOCUMENT
SOC 2 Technical Control Mapping Project**

Classification : Internal
Version : 1.0
Date : March 2026
Author : Patrick Mohlala, GRC Analyst
Review Date : September 2026

1. PURPOSE

This document defines the in-scope AWS Free Tier sandbox used to demonstrate technical cloud security controls mapped to:

- SOC 2 Trust Services Criteria (Security)
- ISO/IEC 27001:2022 Annex A
- POPIA Section 19 Security Safeguards

2. BUSINESS PROBLEM

MediCare Connect already has policies, a risk register, vendor governance, and an incident response plan. Auditors and enterprise customers still ask for technical proof that cloud controls operate. Without mapped cloud evidence, security questionnaires and ISO/SOC discussions stall.

3. ORGANISATION CONTEXT

Company : MediCare Connect (Pty) Ltd
Industry : Private Healthcare
Location : Johannesburg, South Africa
Employees : 45
Data types : Patient clinical documents, staff identity data
Cloud use cases in this lab:

- Encrypted object storage for clinical documents
- Identity and access management
- Audit logging
- Network access restriction
- Monitoring alarms
- Backup configuration

4. IN-SCOPE COMPONENTS

- AWS Account (Free Tier)
- Root account MFA
- IAM users, groups, roles, password policy
- Amazon S3 bucket (simulated document store)
- AWS CloudTrail
- VPC Security Groups
- Amazon CloudWatch basic alarms
- Backup / snapshot configuration notes
- IAM credential report

5. OUT OF SCOPE

- Real patient personal information or medical records
- Production workloads
- Paid SOC 2 Type II audit opinion
- Multi-account AWS Organizations setup
- Full enterprise SIEM platform

6. DATA HANDLING RULES FOR THIS LAB

- No real names, ID numbers, diagnoses, or medical files
- Use dummy filenames only
- Redact account numbers in screenshots where needed

- Never commit AWS access keys to GitHub

7. DATA CLASSIFICATION IN SANDBOX

- Simulated clinical documents = Confidential / Special Personal Information (simulated)
- Configuration and logs = Internal
- Public marketing content = Not used in this lab

8. TRUST SERVICES CRITERIA FOCUS

Primary : Security
Supporting : Availability and Confidentiality concepts
Privacy alignment : Cross-referenced to POPIA

9. ROLES

- GRC Analyst : control mapping, evidence log, reporting
- IT Manager : technical configuration owner
- Information Officer : POPIA alignment review

10. SUCCESS CRITERIA

- At least 15 controls mapped
- At least 10 evidence screenshots captured
- Matrix completed with SOC 2 + ISO 27001 + POPIA references
- Gaps and 30/60/90 actions documented

Document Control

Compiled by : Patrick Mohlala, GRC Analyst
Status : Final